M · SEC

REFERENCE
MSEC-2026-001-SB

SOLUTION BRIEF & HARDENING REPORT

SysWarden Enterprise Host Security Orchestrator

Product overview, independent grey-box security audit results (v0.33.0), and validated remediation roadmap. Zero trust boundary breaches confirmed.

PRODUCT
SysWarden v0.33.0, open-source HIDS/HIPS for Linux

PUBLISHER
DuggyTuxy (Laurent M.), GPLv3

AUDIT PERFORMED BY
M·SEC (Matteo B.), independent offensive security

AUDIT WINDOW
May 11 to May 12, 2026

DOCUMENT TYPE
Solution Brief + Hardening Report

ISSUE DATE
May 13, 2026

M·SEC
Matteo B., independent researcher
m-sec.tech

Confidential document
Restricted distribution to the recipient.
Reproduction prohibited without authorization.

CONFIDENTIAL

CONTENTS

Table of contents

01 The SysWarden Solution 03
02 Independent Security Audit, Key Results 05
03 Findings Summary (15 validated) 06
04 Remediation Roadmap 07
05 Risk Posture: Before vs After 08
06 Why This Matters for Buyers 09

SECTION 01

The SysWarden Solution

SysWarden is an ultra-lightweight, open-source **Enterprise Host-Based Security Orchestrator (HIDS / HIPS)** for Linux. It transforms any bare-metal server or VM into a Zero Trust fortress in minutes, by fusing global threat intelligence, kernel-level packet filtering, a dynamic Layer 7 WAF, and SIEM forwarding into a single coherent control plane.

> **Not "just another fail2ban wrapper."** SysWarden is an orchestrator that wires several best-of-breed primitives into a unified Zero Trust posture, with a single installer, lifecycle management, and dual observability (web dashboard + CLI).

Core Capabilities

LAYER 2/3 HARDWARE-SPEED DROP

Threat intelligence injected into a dedicated `nftables netdev` table. Malicious packets killed at the NIC ingress hook, before kernel routing or conntrack. Zero CPU overhead during volumetric DDoS.

DYNAMIC L7 WAF

Heavily optimized Fail2ban jails protect 51+ services (Nginx, SSH, Docker, databases, CMS). Behavioral bans synchronize back to L2/L3 in seconds.

ZERO TRUST ARCHITECTURE

SSH and admin panels cloaked behind an invisible WireGuard tunnel. Mathematically strict default-deny policy. Only explicitly whitelisted traffic passes.

SMART SIEM FORWARDING

Only high-value L7 behavioral events forwarded to Wazuh/SIEM via rsyslog. L3 noise filtered to prevent index saturation. ISO 27001 and NIS2 alignment.

GLOBAL THREAT INTELLIGENCE

Data-Shield IPv4, CINS Army, Blocklist.de, GeoIP country blocks, and hostile ASN blocks merged and refreshed automatically. ~97% background noise dropped.

LIFECYCLE & SUPPLY CHAIN

Headless deployment via `syswarden-auto.conf` (Ansible/Terraform/cloud-init ready). Signed releases (GitHub Artifact Attestations, SLSA L3). Surgical rollback without reboot.

Supported Platforms

Debian 12+, Ubuntu 24.04+, RHEL 9+, AlmaLinux 10+, Rocky Linux 9+, Fedora 43+. Systemd-based, universal.

Zero Trust Defense Architecture

SysWarden does not simply append rules to standard firewall chains. It fundamentally alters the Linux networking stack to neutralize threats before they consume system resources:

LAYER	COMPONENT	FUNCTION
1	L2/L3 Ingress Drop (Priority -500)	nftables `netdev` family hook at the NIC. OSINT blocklists, hostile ASNs, GeoIP drops enforced before kernel routing or conntrack. Prevents state-table exhaustion.
2	Stateful Fast-Path (Priority 0)	Legitimate established connections and dynamic container traffic (Docker DOCKER-USER chain) prioritized. Zero latency for production traffic.
3	Behavioral L7 Defense	Real-time analysis of application logs (Nginx, SSH, databases). Behavioral anomalies trigger instant, surgical IP bans that synchronize with the L2/L3 drop tables.
4	Zero Trust Catch-All	Any traffic not explicitly whitelisted by the administrator or the automated service discovery engine is silently dropped and logged.

Observability

INTERFACE	CAPABILITIES
Web Dashboard	Live threat telemetry, attacker profiling (top OSINT offenders, ASNs, GeoIP), resource monitoring, jail allocations. Self-hosted at `https://host:9999`.
CLI (`syswarden-manager`)	Terminal dashboard for blocked IPs, whitelists, rule idempotency. Instant shell-based visibility.
SIEM Integration	Native rsyslog forwarding of behavioral L7 events to Wazuh or any SIEM. ISO 27001 / NIS2 compliance artifact.

What SysWarden Orchestrates & Unifies

Rather than replacing specialized enterprise solutions (like EDRs or inline WAFs), SysWarden acts as an uncompromising first line of defense. A single sysadmin delivers in minutes what historically required complex, fragmented manual integrations:

- **Fragmented hardening playbooks:** automates CIS benchmark alignments, strict OS-level restrictions, and Zero Trust network policies out of the box.
- **Manual host-based intrusion prevention (HIPS):** enforces ruthless Drop policies at the kernel level (Layer 3/4), drastically reducing the attack surface and log noise before traffic ever reaches your EDR.
- **Reactive Layer 7 analysis:** dynamically orchestrates edge-level blocking based on application logs, neutralizing brute-force and web exploits to perfectly complement your existing WAF architecture.
- **Complex log routing setup:** standardizes and unifies critical security events for immediate, native forwarding to your existing SIEM infrastructure.

SECTION 02

Independent Security Audit, Key Results

M·SEC conducted a full grey-box penetration test of SysWarden v0.33.0 on May 11-12, 2026, against both the open-source codebase and a live Azure Debian 12 deployment.

PARAMETER	VALUE
Audit posture	Grey-box: source code + live VM, unprivileged shell (sec-admin, uid 1001, no sudo)
Live target	Azure Debian 12, hostname Audit, dashboard TCP/9999, SSH TCP/51815
Methodology	OWASP WSTG v4.2 + CIS Debian 12 Benchmark + PTES
Total findings	15 (2 High, 10 Medium, 3 Low)
Critical / RCE	0
Authentication bypass	0
Trust boundary breaches	0

HEADLINE RESULT

TRUST BOUNDARY HOLDS

No finding compromises the product's stated trust boundary. No remote code execution, no authentication bypass, no privilege escalation from the unprivileged shell to root, no data exfiltration from outside the allowlist. All 15 findings sit in the defense-in-depth and detection coverage layers.

0	2	10	3	0
CRITICAL	HIGH	MEDIUM	LOW	INFO

Closed as "Not a Bug" (validated trust boundary)

- Direct RCE from unprivileged shell
- Config file write or threat-feed injection from sec-admin
- Dashboard HTTP method tampering, hidden API, CORS misconfig
- Writable directories under /etc/syswarden, /etc/fail2ban, /etc/nginx
- Self-DoS via forged syslog injection (defeated by systemd journal backend)

SECTION 03

Findings Summary

ID	TITLE	SEVERITY	CVSS	CATEGORY
F-001	Root cron executes script from /home/pentest (privesc surface)	HIGH	7.8	Local escalation
F-002	sshd jail port mismatch, SSH brute-force unprotected	HIGH	7.5	Configuration
F-003	Stored XSS in dashboard via unprivileged log injection	MEDIUM	6.8	Injection
F-004	Twelve L7 filters inert due to regex bug	MEDIUM	6.5	Detection bypass
F-005	SSRF filter blind to IMDS numeric encodings	MEDIUM	6.5	Detection bypass
F-006	WireGuard active despite disabled flag	MEDIUM	6.5	Configuration
F-007	auto_whitelist_admin picks first SSH peer	MEDIUM	5.9	Access control
F-008	/var/log/auth.log world-readable and injectable	MEDIUM	5.4	Disclosure
F-009	secretshunter filter bypassable via URL encoding	MEDIUM	5.3	Detection bypass
F-010	revshell filter bypassable via encoding + LOLBins	MEDIUM	5.3	Detection bypass
F-011	nginx server_name catch-all (DNS rebinding)	MEDIUM	4.7	Configuration
F-012	fail2ban ignoreip overlaps nginx allowlist	MEDIUM	4.0	Design
F-013	rsyslog SIEM forwarder self-loop	LOW	3.7	Logging
F-014	recidive filter regex broken	LOW	3.7	Detection bypass
F-015	Azure IMDS reachable from unprivileged uid	LOW	3.3	Cloud disclosure

Key insight. The majority of findings stem from missing validations and untested regex chains rather than deep architectural defects. The fixes are inexpensive to deploy and do not require re-architecture.

SECTION 04

Remediation Roadmap

Quick Wins (configuration only, no code change)

ACTION	MITIGATES
Set `server_name <IP or FQDN>` in nginx vhost	F-011: DNS rebinding
Tighten `/var/log/auth.log` to `0640 root:adm`	F-008: world-readable log
Disable recidive jail or fix its regex	F-014: broken escalation
Remove `stop` from rsyslog SIEM template	F-013: self-loop
Block 169.254.169.254 outbound for non-root uids	F-015: IMDS access
Align `ignoreip` with nginx allowlist	F-012: rule shadowing

Code-Level Fixes

ACTION	FINDING	TARGET
Replace L7 filter regex `[^\]]+` with optional date bracket	F-004	14 days
Normalize filter input: percent-decode, lowercase, numeric IP to dotted quad	F-005, F-009, F-010	30 days
Add WireGuard teardown path on flag flip `y` to `n`	F-006	14 days
Refuse auto_whitelist fallback with multiple peers and no tty	F-007	14 days
Move root cron script to `/usr/local/lib/syswarden/` (root-owned)	F-001	7 days
Read SSH `Port` directive at install time for jail config	F-002	7 days

Defense in Depth (Dashboard)

ACTION	BENEFIT
Replace `innerHTML` with `textContent` for telemetry fields	Kills stored XSS class entirely
Tighten CSP: drop `api.github.com`, add `default-src 'none'`	Removes exfiltration channel
Add `Content-Security-Policy-Report-Only` in staging	Continuous regression detection

SECTION 05

Risk Posture: Before vs After Hardening

DIMENSION	BEFORE (V0.33.0 AS SHIPPED)	AFTER REMEDIATION BACKLOG
Remote unauthenticated compromise	Not demonstrated	Not demonstrated
Dashboard auth bypass	Not demonstrated	Not demonstrated
Local privesc, sec-admin to root	Not demonstrated	Not demonstrated
Local privesc, legacy pentest user	Plausible via root cron path	Closed
L7 detection coverage (12 jails)	Inert due to regex bug	Restored
Filter bypass via encoding	Bypassable (3 filters)	Normalization in place
Stored XSS in dashboard	Reachable via log injection	Closed by output encoding
WireGuard stale state	Service stays up on flag flip	Teardown on flag flip
SIEM forwarding completeness	Self-loop drops events	Loop terminated, events flow
SSH brute-force protection	Jail protects wrong port	Port auto-detected at install

Post-hardening posture. After applying the remediation backlog, zero findings remain at High severity. The product's core trust boundary (IP allowlist + WireGuard + root-only install path) is intact and independently validated. All 15 findings are addressable without re-architecture.

Audit Quality Indicators

INDICATOR	VALUE
Findings validated end-to-end on live VM	15 / 15
Reproducible PoCs with full transcripts	15 / 15
Closed negatives (probed, could not exploit)	12 attack vectors
Duplicate/Not-a-Bug pruned during retest	4 (removed from final count)

SECTION 06

Why This Matters for Buyers

OPEN SOURCE, GPLV3

No vendor lock-in. Full source code review is possible and has been independently verified through this audit. Driven by transparent, community-oriented development.

INDEPENDENTLY AUDITED

A comprehensive grey-box audit covering both source code and live deployment surfaced 15 actionable findings, with zero breaches to the core trust boundary. This validates the "production-ready" status of the architecture.

ISO 27001 & NIS2 ALIGNMENT

Compliance is a fundamental design goal, evidenced by concrete artifacts: automated SIEM forwarding, cryptographically signed releases, idempotent deployments, and robust rollback capabilities.

HEADLESS & DEVOPS READY

The `syswarden-auto.conf` architecture makes SysWarden a first-class citizen for automation pipelines (Ansible, Terraform, cloud-init). Deployment requires zero manual intervention.

OPERATIONAL MATURITY

The maintainer strictly processes third-party security findings, remediates root causes with architectural precision, and implements defensive regressions. This rigorous lifecycle separates a standard script from an enterprise-grade security product.

SECURITY CONSOLIDATION & COST EFFICIENCY

Unifies Host Intrusion Prevention (HIPS), native Layer 2/Layer 3/Layer 4 firewall orchestration, and automated OS hardening into a single engine. Rather than replacing specialized EDR or network WAF solutions, SysWarden drastically reduces the attack surface, acting as an uncompromising first line of defense that complements modern XDR architectures. It replaces fragmented hardening playbooks with one installer, one declarative configuration, and one telemetry dashboard, running with absolute efficiency on commodity Linux VMs.

References

- Product repository: github.com/duggytuxy/syswarden
- Documentation: syswarden.io/docs
- Full penetration test report: MSEC-2026-001 (separate document, 34 pages)
- Audit evidence: raw transcripts available under NDA

Prepared by **Matteo B.**, M·SEC
Independent offensive security researcher
m-sec.tech